Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

TEAM MEMBERS

S.no	Name	College	Gmail
1.	G. Beula	V.N.Krishnasamy Naidu college of arts and science	beula1462006@gmail.com
2.	R. Aarthi	V.N.Krishnasamy Naidu college of arts and science	aarthiaarthi31748@gmail.com
3.	S. Nalene	V.N.Krishnasamy Naidu college of arts and science	nalenesathisnalene@gmail.com
4.	V. Dharshana	V.N.Krishnasamy Naidu college of arts and science	dharshanav786@gmail.com
5.	K. Shobika	V.N.Krishnasamy Naidu college of arts and science	shobikakumar70@gmail.com

PROJECT DETAILS

TITLE: Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

This project outlines the strategy and implementation plan for integrating the Zscaler security platform with our organization's core Identity Providers (IdPs): Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). The primary objective is to create a seamless, secure, and automated framework for user authentication and authorization across all Zscaler services.

By moving away from disparate local user management and leveraging these centralized identity sources, we aim to establish a true Zero Trust architecture where access is continuously verified based on user identity and context. This initiative will consolidate authentication into a single source of truth, enforce consistent security policies like Multi-Factor Authentication (MFA), and streamline the user experience through Single Sign-On (SSO).

Ultimately, this integration will serve as the critical link between our identity infrastructure and our security enforcement point, ensuring that the right users have the right level of secure access to the internet and applications, regardless of their location.

ABSTRACT:

This project details the integration of the Zscaler Internet security platform with leading Identity Providers (IdPs), including Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). The primary objective is to establish a unified identity framework that enables seamless Single Sign-On (SSO) and centralized authorization for all Zscaler services. By consolidating authentication into trusted corporate directories, this initiative eliminates the need for disparate credentials and provides a foundational element for a modern Zero Trust security architecture.

By leveraging industry-standard protocols such as SAML, OIDC, and SCIM, this integration ensures that user authentication is delegated to trusted corporate directories while enforcing consistent security policies, including Multi-Factor Authentication (MFA). This approach not only enhances the user experience by reducing password fatigue but also strengthens the organization's security posture by ensuring that every access request is verified by the identity provider before reaching Zscaler's security enforcement points.

Furthermore, the implementation of automated user provisioning via SCIM streamlines lifecycle management, reducing administrative overhead and enhancing security posture. The outcome is a robust, identity-centric security model that aligns with Zero Trust principles, ensuring that only authenticated and authorized users gain secure access to internet and cloud applications from any location. This integration effectively bridges the gap between identity governance and network security, creating a dynamic and responsive access control environment.

USE CASE SCENARIOS:

USE CASE SCENARIO 1: REMOTE FACULTY ACCESS TO RESEARCH DATA

A research professor is working from an off-campus conference and needs secure access to sensitive research data stored on an internal server. Instead of connecting to the full campus network via VPN, ZPA grants access only to the specific research server. The professor authenticates via the university's identity provider, and access is granted based on their role**.**

OUTPUT:

- User identity verified: Research_Faculty_Group
- Context-aware access enforced: Access allowed only from non-campus IP ranges
- Connection restricted: Limited to specific Research File Server (R&D_Server)
- Security enforcement: Multi-Factor Authentication (MFA) required due to off-network location
- No lateral movement: User cannot access other internal systems such as HR or student records

USE CASE SCENARIO 2: STUDENT ACCESS TO LIBRARY RESOURCES

A graduate student is off-campus and needs access to licensed academic journals and databases hosted internally. Instead of requiring a full VPN tunnel, ZPA provides direct access to the library application portal. The student authenticates via the identity provider, ensuring only enrolled students can access paid subscription content**.**

OUTPUT:

- User identity verified: Enrolled_Student_Group
- Access scope defined: Limited to Library Portal and journal databases
- Policy enforcement: Access restricted to authorized users only, preventing credential sharing
- User experience: Seamless SSO without additional VPN client complexity

- No broad network access: Student cannot navigate to administrative systems or internal servers

USE CASE SCENARIO 3: HR ADMINISTRATOR ACCESS TO PAYROLL SYSTEM

An HR administrator requires access to the payroll system to process monthly salaries. Access must be restricted to specific work hours and require step-up authentication due to the sensitivity of the data. The administrator authenticates via the identity provider, and ZPA enforces timebased and MFA policies.

OUTPUT:

- User identity verified: HR_Payroll_Group
- Time-based restriction enforced: Access permitted only during business hours (8:00 AM – 6:00 PM)
- Step-up authentication: MFA triggered upon accessing the payroll application
- Connection restricted: Limited to Payroll Application Server
- Audit trail: Full session logging maintained for compliance purposes

USE CASE SCENARIO 4: IT HELPDESK REMOTE TROUBLESHOOTING

An IT support technician needs to remotely troubleshoot a server issue while working from home. ZPA provides Just-in-Time (JIT) access to the specific server requiring maintenance. The technician authenticates via the identity provider, and administrative privileges are granted only for the duration of the task.

OUTPUT:

- User identity verified: IT_Helpdesk_Group
- Just-in-Time access granted: Admin rights elevated only for the active session
- Connection restricted: Limited to the specific target server (Server-X)
- Privilege boundaries enforced: No access to other infrastructure components (databases, domain controllers)
- Session monitoring: Real-time activity logging for security review

USE CASE SCENARIO 5: CONTRACTOR ACCESS TO PROJECT MANAGEMENT TOOL

An external project manager contracted for a specific initiative needs access to the university's project management tool (e.g., Jira or SharePoint). Access must expire automatically upon contract completion. The contractor authenticates via the identity provider, and ZPA provisions time-limited access based on group membership synchronized from Azure AD.

OUTPUT:

- User identity verified: External_Contractor_Group
- Time-bound access policy enforced: Account deprovisioned automatically after contract end date
- Connection restricted: Limited to Project Management Application only
- Segmentation enforced: Contractor cannot discover or access internal resources like finance systems or student databases

STAGE-1

TITLE OF THE PROJECT: - Integrate Zscaler with Identity Providers(IdPs) such as Azure AD, Okta, and ActiveDirectory for seamless authentication and authorization.

OVERVIEW: -

The integration of Zscaler with enterprise Identity Providers (IdPs) represents a fundamental shift in how organizations approach secure access to applications and resources. Traditional network security models relied on VPNs and perimeter-based defenses, which often granted excessive access and created lateral movement risks. By contrast, this project leverages Zscaler's Zero Trust Exchange platform to verify identity at the application layer rather than the network layer. The integration with leading IdPs such as Microsoft Entra ID, Okta, and on-premises Active Directory establishes a unified identity fabric across the organization. This ensures that users are authenticated consistently regardless of their location or device. The project eliminates the need for duplicate user directories and manual account management within Zscaler. It creates a seamless experience where users authenticate once and gain access to authorized resources. Security teams benefit from centralized control over authentication policies and user lifecycle management. The integration supports modern authentication standards including SAML, OIDC, and SCIM protocols. Ultimately, this foundation enables true Zero Trust security where identity becomes the primary control plane.

Microsoft Entra ID integration serves as a cornerstone of this identity strategy for organizations heavily invested in the Microsoft ecosystem. The integration leverages SAML 2.0 to establish federated trust between Zscaler and Azure AD for seamless Single Sign-On. Users accessing Zscaler Internet Access or Zscaler Private Access portals are redirected to Azure AD for authentication. This allows organizations to enforce Azure AD Conditional Access policies during the authentication flow. Policies can require compliant devices, specific locations, or risk-based access controls before granting access to Zscaler. The integration extends beyond authentication to include automated user provisioning via the SCIM protocol. User accounts and group memberships are synchronized in real-time from Azure AD to Zscaler. This automation eliminates manual provisioning errors and ensures immediate deprovisioning when users leave the organization. Azure AD's extensive reporting and auditing capabilities provide visibility into

authentication attempts. The result is a tightly integrated security posture that leverages Microsoft's identity capabilities to protect Zscaler-enforced resources.

Okta integration provides a flexible and vendor-agnostic approach to identity management for Zscaler deployments. As a leading independent Identity Provider, Okta connects Zscaler to a wide ecosystem of applications and directories. The integration utilizes OpenID Connect (OIDC) for modern, API-friendly authentication to Zscaler services. This approach supports rich user context including profile attributes and group memberships for policy enforcement. Okta's Universal Directory serves as the authoritative source for user identities synchronized from various HR systems and directories. The Okta Integration Network (OIN) simplifies setup with pre-built connectors and configuration guides for Zscaler. Automated provisioning via SCIM ensures that user changes in Okta are reflected in Zscaler within minutes. Lifecycle management events such as user onboarding, role changes, and terminations trigger automatic updates in Zscaler. Okta's adaptive MFA policies add an additional security layer during Zscaler authentication requests. This integration delivers a seamless experience for users while providing administrators with centralized identity governance across all Zscaler services.

On-premises Active Directory integration addresses scenarios where organizations are not ready for full cloud identity migration. Many institutions maintain extensive on-premises infrastructure with complex group policies and nested organizational units. The Zscaler Authentication Bridge (ZAB) enables secure LDAP communication between Zscaler cloud services and on-premises AD. This lightweight connector sits behind the firewall and initiates outbound connections to Zscaler, eliminating the need for inbound firewall rules. User authentication requests are securely proxied through ZAB to validate credentials against the on-premises domain controllers. Group membership information is synchronized to Zscaler for use in policy definitions and access decisions. This approach preserves investments in existing Active Directory infrastructure while enabling cloud-delivered security. Organizations can maintain strict access controls based on onpremises group memberships and organizational hierarchies.

LIST OF VULNERABILITY TABLE:

PRACTICE WEBSITE:

S.no	Vulnerability Name	CWE - No
1	Windows Hard Link	CWE- 65
2	Active Debug Code	CWE-489
3	Unimplemented or Unsupported Feature in UI	CWE-447
4	Insufficient Entropy in PRNG	CWE -332
5	Improper Neutralization of Argument Delimiters in a Command ('Argument Injection')	CWE-88
6	Interpretation Conflict	CWE-436
7	Weak Authentication	CWE-1390
8	Replicating Malicious Code (Virus or Worm)	CWE -509
9	Information Loss or Omission	CWE-221

10	Missing Custom Error Page	CWE-756

REPORT: -

VULNERABILITY NAME: Windows Hard Link
CWE: CWE- 65

OWASP Category: A01:2025 Broken Access Control

Description: A Windows Hard Link vulnerability occurs when an attacker creates a hard link to a sensitive system file and tricks a program or service into modifying or deleting that file. In the Microsoft Windows file system, a hard link is a reference that allows multiple filenames to point to the same file.If an application with higher privileges (like administrator or system) writes to a file without checking for hard links, an attacker can redirect that operation to another important system file. This may allow the attacker to modify, overwrite, or delete protected files.

Business Impact

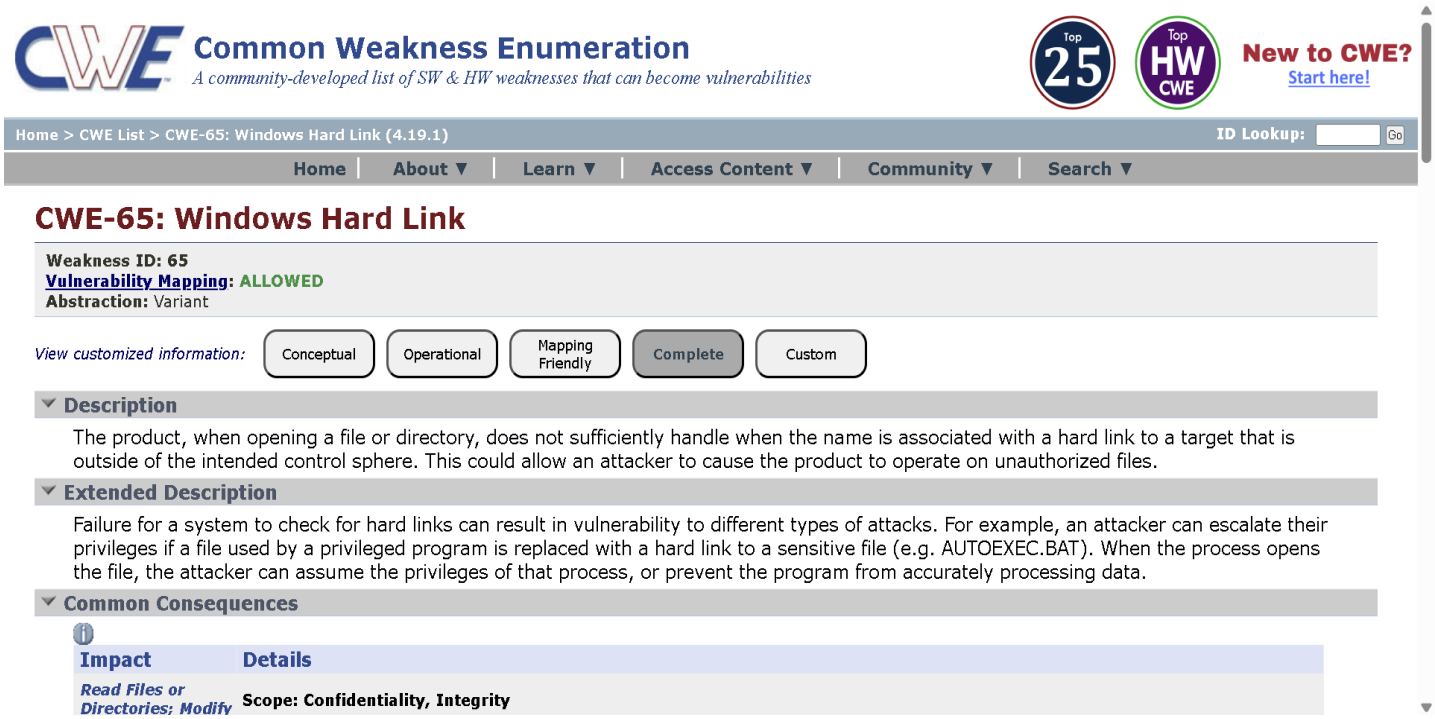
Privilege Escalation – Attackers may gain administrator or system-level access to the system.

Data Loss or Corruption – Important files can be modified or deleted, affecting business operations.

System Compromise – Attackers may install malware or gain full control of the system.

Service Disruption – Critical applications or services may stop working, causing downtime.

Security Breach – Unauthorized access to sensitive business data may occur.



Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-65: Windows Hard Link (4.19.1) | ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-65: Windows Hard Link

Weakness ID: 65
Vulnerability Mapping: ALLOWED
Abstraction: Variant

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product, when opening a file or directory, does not sufficiently handle when the name is associated with a hard link to a target that is outside of the intended control sphere. This could allow an attacker to cause the product to operate on unauthorized files.

Extended Description

Failure for a system to check for hard links can result in vulnerability to different types of attacks. For example, an attacker can escalate their privileges if a file used by a privileged program is replaced with a hard link to a sensitive file (e.g. AUTOEXEC.BAT). When the process opens the file, the attacker can assume the privileges of that process, or prevent the program from accurately processing data.

Common Consequences

Impact	Details
Read Files or Directories; Modify	Scope: Confidentiality, Integrity

2) VULNERABILITY NAME: Active Debug Code

CWE- CWE-489

OWASP Category: A02:2025 Security Misconfiguration

Description

Active Debug Code means the application still contains debugging code, test functions, or developer tools that were used during development but were not removed before deployment. These debug features may allow users to see internal system information, error details, or hidden functions.

If attackers discover this debug code, they can use it to analyze the system, bypass security checks, or gain unauthorized access to the application.

Business Impact

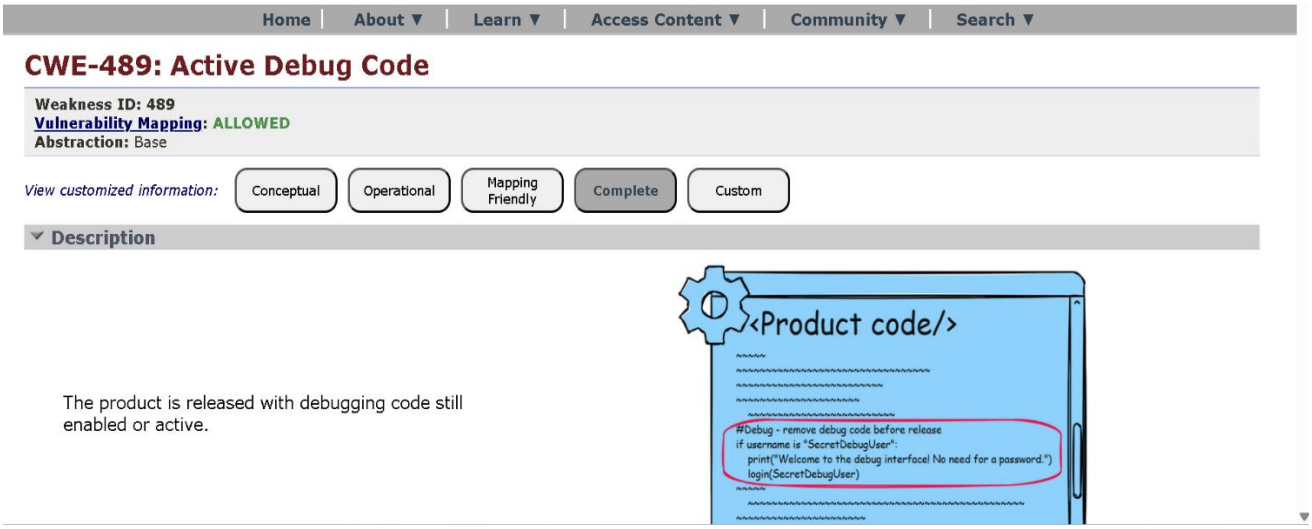
Information Disclosure – Sensitive system details like file paths, database queries, or configuration data may be exposed.

Unauthorized Access – Attackers may exploit debug functions to access restricted areas of the application.

Security Vulnerabilities – Debug code may reveal weaknesses that hackers can exploit.

System Manipulation – Attackers may modify application behavior using exposed debug tools.

Reputation Damage – Security breaches can reduce customer trust and harm the organization's reputation.



3) VULNERABILITY NAME: Unimplemented or Unsupported Feature in UI

CWE- CWE-447

OWASP Category: A03:2025 Software Supply Chain Failures

Description

An Unimplemented or Unsupported Feature in UI occurs when a button, link, option, or feature appears in the user interface but is not actually implemented or supported in the system. When users click or use these features, the system may show an error, unexpected behavior, or reveal internal system details.

This happens when developers leave incomplete features, test options, or disabled functions visible in the application interface.

Business Impact

Security Risk – Attackers may try to exploit these incomplete features to find system weaknesses.

Information Exposure – Error messages may reveal internal system details.

Poor User Experience – Users may get confused or frustrated when features do not work.

System Errors – The application may crash or behave unexpectedly.

Reputation Damage – Users may lose trust in the quality and reliability of the system.

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-447: Unimplemented or Unsupported Feature in UI

Weakness ID: 447
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

A UI function for a security feature appears to be supported and gives feedback to the user that suggests that it is supported, but the underlying functionality is not implemented.

Common Consequences

Impact	Details
Varies by Context; Unexpected State	**Scope: Other**

4) **VULNERABILITY NAME:** Insufficient Entropy in PRNG

CWE - CWE -332

OWASP Category: A04:2025 Cryptographic Failures

Description

Insufficient Entropy in PRNG occurs when a Pseudo-Random Number Generator (PRNG) does not produce truly random values because it uses weak or predictable input (low entropy). In many systems, PRNG is used to generate session IDs, encryption keys, passwords, and security tokens.

If the randomness is weak or predictable, attackers may be able to guess or predict these values, which can compromise the security of the system.

Business Impact

Session Hijacking – Attackers may guess session IDs and take control of user accounts.

Weak Encryption – Predictable random numbers can weaken cryptographic keys.

Unauthorized Access – Attackers may bypass authentication mechanisms.

Data Breach – Sensitive business or customer data may be exposed.

Loss of Trust – Security failures can damage the organization’s reputation and customer confidence.

5) VULNERABILITY NAME: Improper Neutralization of Argument Delimiters in a Command ('Argument Injection')
CWE-: CWE-88
OWASP Category: A05:2025 Injection

Description

This vulnerability occurs when an application does not properly validate or sanitize user input before passing it to a system command. Attackers can insert special characters or additional arguments into the command, which changes how the command is executed.

Because the application fails to neutralize these argument delimiters, the attacker may be able to inject malicious parameters and make the system run unintended commands.

Business Impact

Unauthorized Command Execution – Attackers may run harmful commands on the system.

System Compromise – The attacker may gain control over the server or application.

Data Theft or Loss – Sensitive business or customer data may be accessed or deleted.

Service Disruption – Critical services may stop working, causing downtime.

Reputation Damage – Security incidents can reduce customer trust and harm the organization's reputation.

CWE-332: Insufficient Entropy in PRNG

Weakness ID: 332
Vulnerability Mapping: ALLOWED
Abstraction: Variant

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The lack of entropy available for, or used by, a Pseudo-Random Number Generator (PRNG) can be a stability and security threat.

Common Consequences

Impact	Details
DoS: Crash, Exit, or Restart	**Scope: Availability** If a pseudo-random number generator is using a limited entropy source which runs out (if the generator fails closed), the program may pause or crash.
	Scope: Access Control, Other

6) VULNERABILITY NAME: Interpretation Conflict

CWE- CWE-436

OWASP Category: A06:2025 Insecure Design

Description

Interpretation Conflict occurs when different components of a system interpret the same input in different ways. For example, the web server, application, or security filter may process the input differently. Because of this mismatch, an attacker may send specially crafted data that bypasses security checks or validation in one component but is executed by another component.

Business Impact

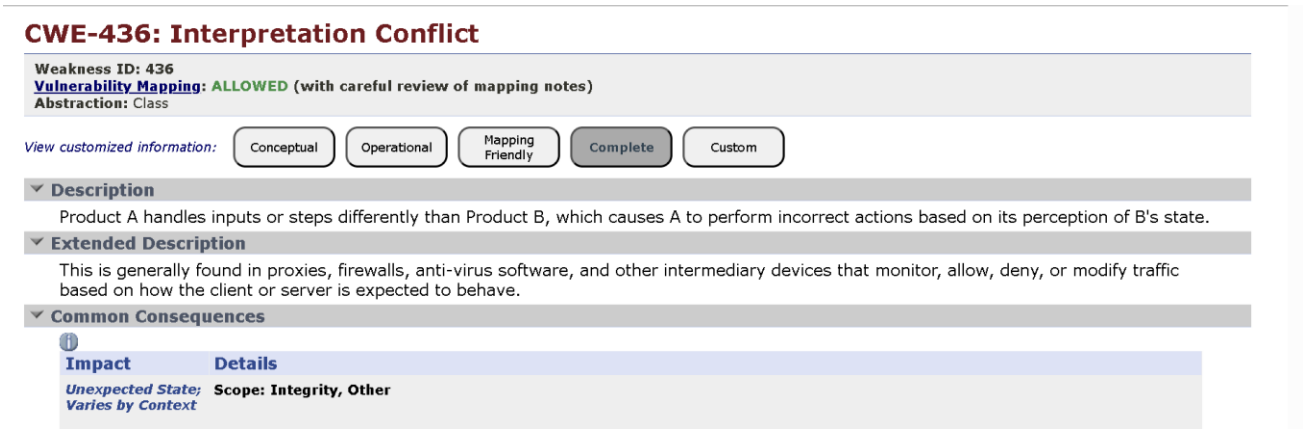
Security Bypass – Attackers may bypass security filters or validation mechanisms.

Unauthorized Access – Malicious users may gain access to restricted functions or data.

Data Manipulation – Attackers may modify or inject harmful data into the system.

System Vulnerability – The application may become exposed to other attacks.

Reputation Damage – Security issues can reduce user trust and affect the organization's reputation.



CWE-436: Interpretation Conflict

Weakness ID: 436
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

Product A handles inputs or steps differently than Product B, which causes A to perform incorrect actions based on its perception of B's state.

Extended Description

This is generally found in proxies, firewalls, anti-virus software, and other intermediary devices that monitor, allow, deny, or modify traffic based on how the client or server is expected to behave.

Common Consequences

Impact	Details
Unexpected State; Varies by Context	**Scope: Integrity, Other**

7) VULNERABILITY NAME: Weak Authentication
CWE-79: CWE-1390
OWASP Category: A07:2025 Authentication Failures

Description

Weak Authentication occurs when an application uses insecure or insufficient methods to verify a user's identity. This can happen when the system allows simple passwords, lacks proper verification, or does not implement strong authentication mechanisms. Because of this weakness, attackers may be able to easily guess or bypass the login process.

Business Impact

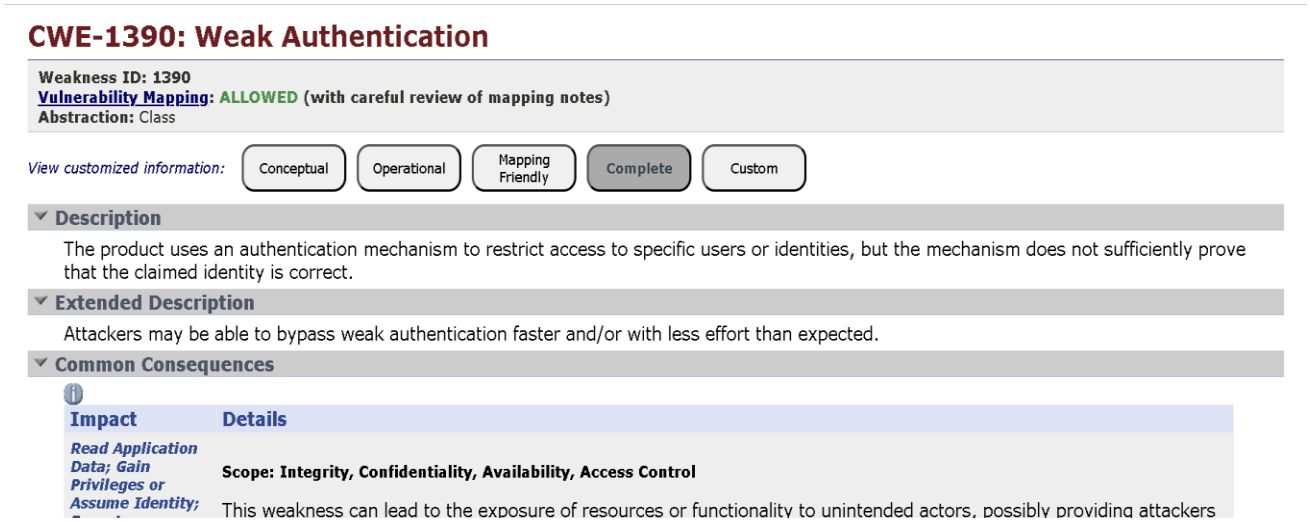
Unauthorized Access – Attackers may gain access to user or admin accounts.

Data Breach – Sensitive customer or business data may be exposed.

Account Takeover – Legitimate users may lose control of their accounts.

Financial Loss – Unauthorized transactions or misuse of resources may occur.

Reputation Damage – Security breaches can reduce customer trust in the organization.



CWE-1390: Weak Authentication

Weakness ID: 1390
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product uses an authentication mechanism to restrict access to specific users or identities, but the mechanism does not sufficiently prove that the claimed identity is correct.

Extended Description

Attackers may be able to bypass weak authentication faster and/or with less effort than expected.

Common Consequences

Impact	Details
Read Application Data; Gain Privileges or Assume Identity;	**Scope: Integrity, Confidentiality, Availability, Access Control** This weakness can lead to the exposure of resources or functionality to unintended actors, possibly providing attackers

8)VULNERABILITY NAME: Replicating Malicious Code (Virus or Worm)

CWE - CWE -509

OWASP Category: A08:2025 Software or Data Integrity Failures

Description

Replicating malicious code refers to harmful software such as a virus or worm that can automatically copy and spread itself to other files, programs, or systems. A virus attaches itself to a legitimate file or program, while a worm spreads across networks without user interaction.

These malicious programs can exploit system vulnerabilities to infect multiple systems, damage files, or steal sensitive information.

Business Impact

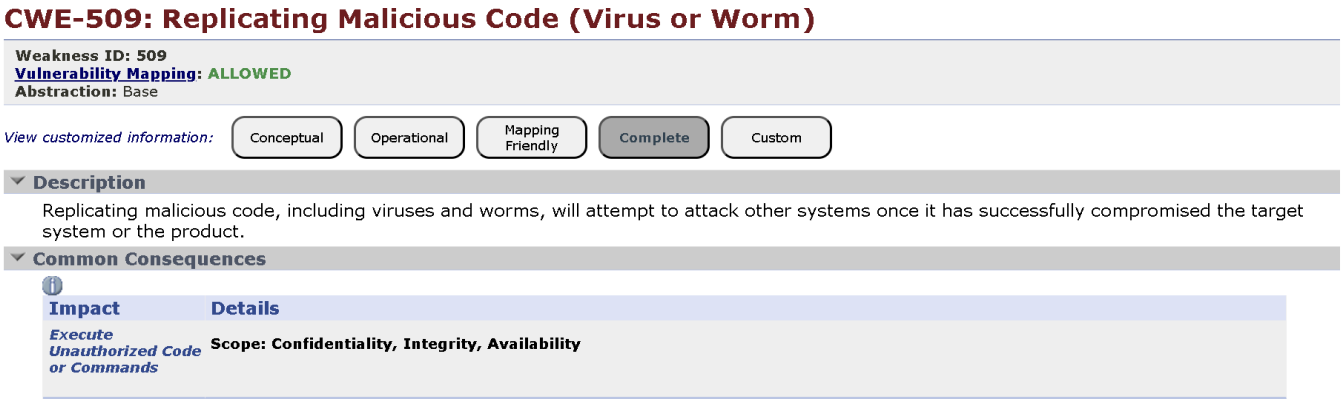
System Infection – Multiple computers in the organization may become infected.

Data Loss or Corruption – Important files may be damaged or deleted.

Network Disruption – The malware may slow down or crash network systems.

Financial Loss – Businesses may spend money on recovery, security fixes, and downtime.

Reputation Damage – Security incidents can reduce customer trust in the organization.



CWE-509: Replicating Malicious Code (Virus or Worm)

Weakness ID: 509
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

Replicating malicious code, including viruses and worms, will attempt to attack other systems once it has successfully compromised the target system or the product.

Common Consequences

Impact	Details
Execute Unauthorized Code or Commands	**Scope: Confidentiality, Integrity, Availability**

9) VULNERABILITY NAME: Information Loss or Omission

CWE- CWE-221

OWASP Category: A09:2025 Security Logging & Alerting Failures

Description

Information Loss or Omission occurs when important data is lost, not recorded, or accidentally removed during system processing, storage, or communication. This may happen because of software errors, system

failures, incorrect data handling, or poor validation. As a result, the system may produce incomplete or inaccurate information.

Business Impact

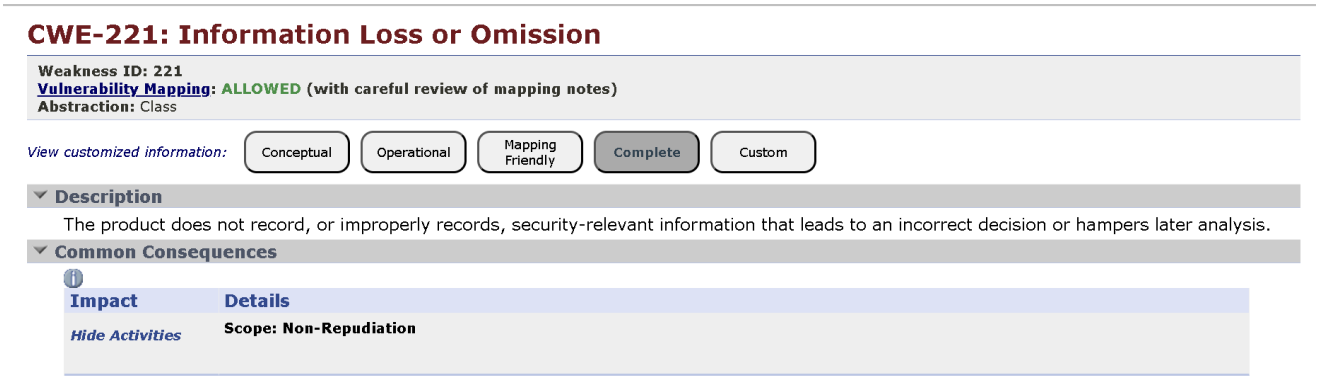
Data Inaccuracy – Missing information can lead to incorrect reports or decisions.

Operational Issues – Business processes may fail due to incomplete data.

Compliance Problems – Missing records may violate legal or regulatory requirements.

Financial Loss – Incorrect data may cause billing or transaction errors.

Loss of Trust – Customers may lose confidence in the organization's data reliability.



10) VULNERABILITY NAME: Missing Custom Error Page

CWE- CWE-756
OWASP Category: A10:2025 Mishandling of Exceptional Conditions

Description

Missing Custom Error Page occurs when a web application does not provide custom error messages for situations like 404 (page not found) or 500 (server error). Instead, the server shows default error pages. These default pages may reveal technical details such as server information, file paths, or software versions, which attackers can use to understand the system structure.

Business Impact

Information Disclosure – Attackers may obtain sensitive technical details about the system.

Increased Security Risk – Exposed information can help attackers plan further attacks.

Poor User Experience – Users may see confusing or technical error messages.

System Targeting – Hackers may identify vulnerabilities based on server details.

Reputation Damage – Unprofessional error pages may reduce user trust in the application.

CWE-756: Missing Custom Error Page

Weakness ID: 756
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product does not return custom error pages to the user, possibly exposing sensitive information.

Common Consequences

Impact	Details
Read Application Data	**Scope: Confidentiality** Attackers can leverage the additional information provided by a default error page to mount attacks targeted on the framework, database, or other resources used by the application.

STAGE 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices. ● Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/
Target ip address:- 65.61.137.117

List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing From HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107

REPORT: -

1) **Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection**

Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these

problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.
PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.
Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.
Business Impact: -Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non-compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated
Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1 As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact: -The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

3) Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)
Severity: - LOW

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

4) Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure

Severity: - INFO

Plugin: - 10114

Port: - 0

Description: - The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact: -This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

5) Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com [192.0.32.10]

Business Impact: -This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure. Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

6) Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact: -Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

7) Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590

Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

Business Impact: - This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

8) Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: -

Business Impact: - It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network. This information aids in network management, optimization, and ensures that the right security measures are in place for each device type.

9) Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Severity: - INFO

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security (HSTS). HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS**.**

Business Impact: -Indicates that the remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is a crucial security feature that, when configured on the server, instructs web browsers to communicate exclusively via HTTPS, enhancing security. The absence of HSTS potentially exposes the server to downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens protections against cookie hijacking, posing risks to data confidentiality and user security. Enabling HSTS is essential to ensure a higher level of protection for data transmitted between clients and the server.

10) Vulnerability Name: - 10107 - HTTP Server Type and Version

Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

Business Impact: -This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture.

STAGE-3

Title: - Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Overview:

This project focuses on integrating the cloud-based security platform Zscaler with Identity Providers (IdPs) such as Microsoft Azure Active Directory, Okta, and Active Directory to provide secure and centralized user authentication. Identity Providers are systems that manage user identities and verify whether users are allowed to access certain applications or network resources.

In modern organizations, employees need to access multiple applications and cloud services from different devices and locations. Without proper identity management, it becomes difficult to control who can access sensitive information. By integrating Zscaler with Identity Providers, organizations can implement Single Sign-On (SSO), which allows users to log in once and securely access multiple services without repeatedly entering their credentials.

This integration also improves security and access control by verifying user identity before granting access to applications or networks. Zscaler applies security policies based on user identity, device, and location to ensure that only authorized users can access organizational resources. This helps protect the organization from cyber threats such as unauthorized access, data breaches, and malware attacks.

Additionally, integrating Zscaler with Identity Providers simplifies user management and administration. IT administrators can manage user authentication, permissions, and access policies from a centralized platform. This reduces complexity, improves efficiency, and enhances the overall security posture of the organization while providing a smooth and secure user experience.

Conclusion: -

In Stage 1, the project focused on understanding the fundamentals of web application security testing. This stage helped in identifying different types of vulnerabilities that can affect web applications. Through testing and analysis, it became clear that web applications must be regularly monitored to detect potential security risks. The knowledge gained in this stage provided a strong foundation for understanding how attackers exploit weaknesses in systems. By learning about vulnerability identification and risk analysis, it became easier to evaluate the security posture of web-based systems. Overall, Stage 1 emphasized the importance of proactive security testing to protect sensitive data and ensure the reliability of online applications.

In Stage 2, the focus shifted to analysing vulnerability reports generated by the Nessus scanning tool. Nessus helped in detecting multiple security weaknesses present in the tested systems. By studying the vulnerability reports, it was possible to understand the severity level of each vulnerability and its potential impact on system security. This stage highlighted how detailed vulnerability assessment can help organizations identify risks before attackers exploit them. The analysis also helped in suggesting appropriate mitigation strategies to improve security. Overall, Stage 2 demonstrated the importance of using automated security tools to detect, analyse, and manage vulnerabilities effectively.

In Stage 3, the project focused on implementing a modern security approach by integrating Zscaler with enterprise Identity Providers such as Azure AD, Okta, and Active Directory. This integration replaces traditional VPN-based security models with a Zero Trust security framework. Instead of granting full network access, users are verified based on identity and allowed to access only specific applications. This reduces the risk of unauthorized access and prevents attackers from moving laterally inside the network. The implementation of Single Sign-On and Multi-Factor Authentication improves both security and user experience. Overall, this stage demonstrated how modern cloud-based security solutions can provide strong protection, centralized identity management, and secure application access for organizations.

Future Scope

In the future, web application security testing can be enhanced by using more advanced security tools and automated testing frameworks. Organizations can implement continuous security monitoring to detect vulnerabilities in real time. Artificial Intelligence and Machine Learning techniques can also be used to identify unusual activities and potential threats automatically. In addition, developers can follow secure

coding practices during the development stage to reduce vulnerabilities before deployment. Regular security audits and penetration testing can further strengthen the protection of web applications. These improvements will help organizations maintain a secure and reliable web environment.

For future improvements, vulnerability analysis using Nessus can be expanded by integrating it with other security management platforms and monitoring tools. Automated patch management systems can be implemented to fix detected vulnerabilities quickly. Organizations can also schedule regular vulnerability scans to continuously monitor system security. Advanced reporting and risk analysis techniques can be used to prioritize vulnerabilities based on their severity. Integration with Security Information and Event Management (SIEM) systems can provide better threat detection and incident response. These developments will improve vulnerability management and help organizations respond quickly to emerging security threats.

In the future, the integration of Zscaler with identity providers can be expanded to support more cloud applications and enterprise systems. Advanced authentication methods such as biometric authentication and adaptive authentication can be implemented to further enhance security. Artificial Intelligence can also be used to detect abnormal login behavior and prevent potential cyber attacks. The Zero Trust security model can be extended across all devices, including mobile and IoT devices. In addition, improved automation and policy management can simplify access control for administrators. These advancements will help organizations build a stronger, more scalable, and more secure access management system.

Topics explored: -

- Introduction to web application security and its importance in modern organizations.
- Understanding different types of cybersecurity threats and vulnerabilities.
- Basics of vulnerability assessment and security testing.
- Use of Nessus vulnerability scanner for detecting security weaknesses.
- Analysis of vulnerability reports and severity levels.
- Understanding the OWASP Top 10 security risks in web applications.
- Concepts of Zero Trust Security Model and secure access control.
- Integration of Zscaler with Identity Providers for secure authentication.

- Working with Identity Management Systems such as Azure Active Directory, Okta, and Active Directory.
- Implementation of Single Sign-On (SSO) and Multi-Factor Authentication (MFA).
- Use of authentication protocols like SAML and OpenID Connect.
- Importance of secure access management and data protection in organizations.

Tools explored: -

- Zscaler – Used as a cloud-based security platform to provide secure access to applications and internet services using the Zero Trust security model.
- Nessus – A vulnerability scanning tool used to identify security weaknesses, misconfigurations, and potential threats in systems and web applications.
- Azure Active Directory (Azure AD) – A cloud-based identity and access management service used to manage user authentication and authorization.
- Okta – An identity management platform used for secure user authentication, Single Sign-On (SSO), and identity federation.
- Active Directory (AD) – A directory service used for managing users, devices, and access permissions within an organization.
- OWASP Security Guidelines – Used as a reference for identifying common web application vulnerabilities and improving application security.
- Web Browsers and Testing Environment – Used to access applications, perform security testing, and verify authentication processes.

THE END